

Zadanie: Wykrycie i obsługa incydentu bezpieczeństwa

Autor: Michał Błaszczkowski WCY24IB1S4

Data: 11.12.2025r.

OPIS SYTUACJI

Krótką charakterystyka sytuacji: W poniedziałek o godzinie 09:15 Pani Anna z Działu Księgowości zgłosiła do Helpdesku, że nie może otworzyć plików Excela, nad którymi pracowała. Zamiast arkuszy widzi komunikaty o błędzie formatu, a ikony plików zmieniły się na białe kartki. Dodatkowo na pulpicie pojawił się nowy plik tekstowy o nazwie DECRYPT_FILES.txt, a tło pulpitu zmieniło się na czarne z czerwonym napisem ostrzegawczym. Komputer działa bardzo wolno, a wentylatory pracują na maksymalnych obrotach. Analiza wstępna wykazała, że 15 minut wcześniej Pani Anna otworzyła załącznik "Faktura_Korekta_Zalegla.js" z wiadomości e-mail, która podszywała się pod stałego kontrahenta firmy.

A. Wykrycie i klasyfikacja incydentu

1. Czy opisane zdarzenie można uznać za incydent bezpieczeństwa? Tak. Jest to krytyczny incydent bezpieczeństwa. Doszło do skutecznego uruchomienia złośliwego kodu, który naruszył integralność i dostępność danych firmowych, paraliżując pracę działu księgowości.

2. Jakiego typu incydemtem może być? Jest to atak typu Ransomware (oprogramowanie szyfrujące dla okupu).

- Wektor ataku: Phishing / Malspam (złośliwy załącznik JavaScript).
- Mechanizm: Złośliwy skrypt pobrał i uruchomił payload szyfrujący pliki lokalne oraz zasoby sieciowe.

3. Prawdopodobna utrata których atrybutów bezpieczeństwa?

- **Dostępność (Availability):** Krytyczna utrata. Pliki są zaszyfrowane i nieczytelne dla użytkownika.
- **Integralność (Integrity):** Struktura plików została nieodwracalnie zmodyfikowana przez algorytm szyfrujący.
- **Poufność (Confidentiality):** Potencjalna utrata. Nowoczesne grupy ransomware stosują tzw. "double extortion" (podwójne wymuszenie) – przed zaszyfrowaniem danych często je wykradają (exfiltracja).

4. Jakie dowody potwierdzają, że zachowanie jest podejrzane?

- **Plik z żądaniem okupu:** Obecność pliku DECRYPT_FILES.txt (Ransom Note).
- **Zmiana rozszerzeń plików:** Pliki użytkownika mają zmienione rozszerzenia (np. na .locked lub losowy ciąg znaków).
- **Wysokie użycie zasobów:** Proces szyfrowania zużywa dużo mocy obliczeniowej CPU (głośna praca wentylatorów).
- **Anomalia w logach:** Uruchomienie skryptu .js (Windows Script Host) spoza katalogów systemowych.

B. Scenariusz postępowania z incydem

Poniższa procedura IR (Incident Response) jest zgodna z cyklem życia incydentu wg NIST SP 800-61.

1. Identyfikacja (Identification)

Jakie logi należy przeanalizować?

- **Windows Event Logs (Security & Sysmon):**
 - Szukamy Event ID 4688 (Process Creation) dla procesu wscript.exe lub cscript.exe (uruchomienie pliku .js).
 - Sysmon Event ID 11 (File Create) – masowe tworzenie plików w krótkim czasie.
- **Logi sieciowe (Firewall/Proxy):** Sprawdzenie połączeń wychodzących w momencie infekcji (komunikacja z serwerem C2 w celu pobrania klucza szyfrującego).
- **Logi serwera plików (SMB):** Jeśli Pani Anna miała zamapowane dyski sieciowe, należy sprawdzić, czy z jej adresu IP nastąpiła masowa modyfikacja plików na serwerze.

Jakie artefakty zabezpieczyć?

- **Zrzut pamięci RAM:** Wykonany narzędziem takim jak *Dumplt* lub *FTK Imager* (przed wyłączeniem maszyny!), aby spróbować odzyskać klucze szyfrujące (rzadko skuteczne, ale konieczne) oraz zbadać procesy w pamięci.
- **Złośliwy plik (Dropper):** Plik Faktura_Korekta_Zalegla.js z folderu Pobrane/Temp.
- **Próbki zaszyfrowanych plików:** Kilka plików przed i po szyfrowaniu do analizy.

- **Notatka z żądaniem okupu:** Może zawierać identyfikator ataku lub nazwę grupy przestępczej.

Jak potwierdzić obecność np. malware?

- **Analiza Entropii:** Zaszyfrowane pliki mają bardzo wysoką entropię (bliską losowości).
- **Hash Check:** Wyliczenie sumy kontrolnej (SHA256) podejrzanego pliku .js lub .exe i sprawdzenie jej w bazie Threat Intelligence (np. VirusTotal, AlienVault OTX).

2. Izolacja (Containment)

W jaki sposób odłączyć urządzenie od sieci?

- **Natychmiastowa izolacja logiczna (EDR):** Jeśli na stacji jest agent EDR (Endpoint Detection and Response), użyć funkcji "Isolate Host". Pozwoli to odciąć komunikację z siecią firmową i Internetem, ale zachowa połączenie z konsolą administracyjną dla celów śledczych.
- **Izolacja fizyczna (Plan B):** Jeśli brak EDR, fizyczne wypięcie kabla sieciowego LAN i wyłączenie Wi-Fi. **UWAGA:** Nie wyłączamy zasilania komputera, jeśli trwa szyfrowanie, chyba że ryzyko dla sieci jest krytyczne – wyłączenie zasilania niszczy dowody w RAM.

Jakie działania zapobiegawcze wdrożyć natychmiast?

- **Blokada konta użytkownika:** Reset hasła i zablokowanie konta Pani Anny w Active Directory.
- **Odcięcie udziałów sieciowych:** Tymczasowe przetączenie udziałów sieciowych, do których użytkownik miał dostęp, w tryb "Read-Only", aby zatrzymać postępujące szyfrowanie danych na serwerze.
- **Blokada na Firewallu:** Zablokowanie adresów IP i domen zidentyfikowanych jako serwery C2 (Command & Control) atakującego.

3. Eliminacja zagrożenia (Eradication)

Jak usunąć złośliwe pliki i procesy?

- W przypadku ransomware **nie zaleca się "leczenia" systemu**. Zaufanie do stacji zostało całkowicie utracone.
- Formalnie: procesy złośliwe zabijamy (Kill Process), a pliki usuwamy, ale tylko w celu analizy powłamaniowej na obrazie dysku.

Jak sprawdzić, czy atakujący nie pozostawił backdoorów?

- Analiza mechanizmów persystencji:

- **Rejestr:** Klucze HKCU\Software\Microsoft\Windows\CurrentVersion\Run.
- **Harmonogram Zadań:** Nowe, podejrzone zadania w *Task Scheduler*.
- **Folder Autostart:** Obecność skryptów lub skrótów.
- Sprawdzenie, czy nie utworzono nowych kont lokalnych z uprawnieniami administratora.

Jak zweryfikować integralność systemu?

- W środowisku korporacyjnym po ataku ransomware **jedyną akceptowalną metodą** weryfikacji jest uznanie systemu za skompromitowany. Należy sformatować dysk twardy (po zabezpieczeniu dowodów). Próba "czyszczenia" antywirusami nie daje 100% gwarancji usunięcia rootkitów lub backdoorów.

4. Odtwarzanie (Recovery)

Jak bezpiecznie przywrócić urządzenie do pracy?

1. **Reimaging:** Całkowite wyczyszczenie dysku (Wipe) i instalacja czystego obrazu systemu ("Golden Image") z zaufanego źródła.
2. **Odtworzenie danych:** Przywrócenie plików z **kopii zapasowej (backup)** wykonanej przed datą infekcji (weryfikacja daty backupu jest kluczowa, aby nie przywrócić zainfekowanych plików).

Jakie testy bezpieczeństwa wykonać po stronie użytkownika?

- Pełne skanowanie antywirusowe odtworzonych danych.
- Wymuszenie zmiany haseł do wszystkich systemów, do których Pani Anna logowała się ze stacji.
- Weryfikacja uprawnień użytkownika (czy nie ma nadmiarowych praw administratora).

Jak monitorować ewentualny powrót zagrożenia?

- Wdrożenie reguł monitorujących w SIEM dla tej stacji (tzw. *Hyper-care period* – np. przez 48h).
- Monitorowanie prób połączeń do znanych IoC (Indicators of Compromise) związanych z tym atakiem.

5. Wnioski i działania po incydencie (Post-Incident)

Jak przygotować raport incyduentu? Raport musi zawierać sekcje:

- **Streszczenie zarządcze:** Jaki był wpływ biznesowy (przestój księgowości).

- **Oś czasu (Timeline):** Od otrzymania maila do przywrócenia systemu.
- **IoC:** Lista hashy plików, adresów IP do zablokowania w innych firmach/oddziałach.
- **Analiza przyczyn źródłowych (Root Cause Analysis):** Błąd ludzki + brak blokady wykonywania skryptów .js z poziomu poczty.

Jakie rekomendacje wdrożyć?

- **Zmiana polityk:** Zablokowanie na bramce pocztowej przyjmowania załączników wykonywalnych (w tym .js, .vbs).
- **Hardenizacja:** Zmiana domyślnego skojarzenia plików .js w systemie Windows, aby otwierały się w Notatniku, a nie wykonywały przez WSH (Windows Script Host).
- **Szkolenia:** Przeprowadzenie warsztatów phishingowych dla działu finansów.
- **Backup:** Weryfikacja zasady 3-2-1 dla backupów (kopie offline, odporne na ransomware).

Jak podnieść poziom detekcji na przyszłość?

- Wdrożenie lub dostrojenie systemu EDR/XDR, aby automatycznie blokował procesy masowo zmieniające nazwy plików.
- Konfiguracja honeypotów (plików-pułapek) na udziałach sieciowych – próba ich zaszyfrowania wywoła natychmiastowy alarm.